

PLANO DE TRABALHO PARA A EQUIPE TÉCNICA

Pendências para colocar o PsicoGest em produção

Clínica de psicologia e psicanálise

Data de referência 25 de setembro de 2026

Destinatários os dois responsáveis técnicos do projeto

Preço comercial informado R\$299 por mês

Orçamento inicial de hospedagem R\$0

Decisão recomendada

Iniciar por um ambiente gratuito com dados fictícios e preparar, em paralelo, os controles para uso clínico. A entrada de pacientes reais depende da identificação da base existente, recuperação comprovada, isolamento entre organizações, integrações necessárias e aceite dos responsáveis da clínica.

O projeto ainda precisa de evidências para ser liberado. Código existente, contas abertas e uma página acessível não comprovam que o serviço esteja pronto para atender a clínica.

O que precisa ser resolvido primeiro

- Identificar a base já existente e confirmar se contém dados reais ou atende uma operação ativa.
- Fechar o escopo inicial e separar recursos clínicos de pagamentos, mensagens, assinaturas e emissão fiscal.
- Concluir a ligação com storage privado e validar banco, Redis, chaves, HTTPS e autenticação no provedor escolhido.
- Ensaiar restauração e upgrade em ambiente isolado, incluindo o histórico do Flyway e a interpretação de datas da V86.
- Concluir revisão independente, documentos de privacidade, suporte e aprovação do piloto.

Como usar este documento

A página 2 organiza as prioridades. As páginas 3 a 13 detalham execução e critérios de aceite. As páginas 14 e 15 trazem divisão de trabalho e registro de liberação. As fontes e o glossário estão na página 16.

As pendências estão classificadas como desenvolvimento, configuração, validação ou decisão externa. A existência de uma proteção no código deve ser acompanhada de testes na versão candidata e no ambiente que será utilizado.

VISÃO DE EXECUÇÃO

Mapa das pendências e prioridades

P0 impede uso com dados clínicos reais. **P1** impede ativar o módulo correspondente. Um módulo P1 só pode ficar para depois se estiver fora do escopo contratado e efetivamente bloqueado. Todos os itens abaixo aguardam evidência de conclusão.

ID	Nível	Pendência	Responsável proposto
01	P0	Identificar e preservar a base existente	B + clínica
02	P0	Consolidar versão candidata e alterações locais	A + B
03	P0	Infraestrutura segura e capacidade comprovada	A
04	P0	Storage privado conectado e recuperação de chaves	B + A
05	P0	Backup, PITR e ensaio de recuperação	B
06	P0	Upgrade validado em cópia e aprovação da V86	B + revisor
07	P0	Isolamento, permissões, MFA e sessões	A + B
08	P0	Testes, revisão independente e reteste	A + avaliador
09	P0	Logs, alertas, suporte e contingência	A + clínica
10	P0	Privacidade, retenção, contratos e incidentes	Clínica + jurídico
11	P1	Pagamento e cobrança da assinatura SaaS	B + clínica
12	P1	E-mail e WhatsApp homologados	B + clínica
13	P1	NFS-e e certificado no canal aplicável	B + contador
14	P0	Aceite do escopo, treinamento e início do piloto	A + B + clínica

A e B são papéis propostos, a atribuir entre os dois amigos. O executor não deve ser o único a validar tarefas críticas. As decisões contábeis e jurídicas continuam com os responsáveis habilitados.

O que já existe e precisa ser comprovado

Há perfil de produção, validações de segurança, migrations, scripts de backup e restore, testes e pipeline de qualidade. Também há novos controles de escopo do piloto e uma camada de exportação cifrada. Isso reduz o trabalho de implementação, mas não elimina configuração, integração ou homologação. [R1 a R7]

DECISÃO DE INFRAESTRUTURA

Hospedagem gratuita e limite do orçamento

A proposta inicial é testar Render, Supabase e Upstash com dados fictícios. A adequação da API Java e das integrações precisa ser medida. Nenhum serviço deve ser contratado em plano pago sem definir previamente o orçamento.

Serviço	Uso proposto	Limite confirmado
Render Free	Interface e API via Docker	API suspende após 15 minutos sem tráfego; armazenamento local é temporário.
Supabase Free	PostgreSQL e storage privado de teste	500 MB de banco, 1 GB de arquivos; pausa por inatividade; sem backup automático/PITR.
Upstash Free	Redis para testes	256 MB e 500 mil comandos por mês; acompanhar consumo.

Fontes oficiais dos planos: [S1], [S2] e [S3]. A documentação do Render desaconselha instâncias gratuitas em produção; seu PostgreSQL gratuito expira após 30 dias. Não usá-lo para preservar a base da clínica.

O que permanece sem atendimento

- A combinação não entrega automaticamente rede privada entre fornecedores, KMS sob controle da clínica, backup imutável ou recuperação ponto a ponto.
- A hospedagem gratuita não paga domínio, certificado fiscal, taxas por transação/mensagem, avaliação independente ou assessoria jurídica.
- Um plano pago básico também não comprova todos os requisitos: verificar cada recurso, sua disponibilidade regional e seu custo separadamente.

Controle dos R\$299 por mês

R\$299 é o preço comercial informado, não o orçamento disponível para infraestrutura. Antes de vender uma operação contínua, registrar custos fixos, custo variável por clínica, impostos, suporte e reserva para incidentes. Definir o que está incluído na assinatura e o que será cobrado à parte.

Conta de planejamento

Receita recebida - tributos - infraestrutura - fornecedores - suporte = saldo antes dos demais custos. Preencher com cotações reais; este plano não pressupõe margem nem quantidade de clientes.

Critério de conclusão

Contas com acesso individual e MFA; planos e regiões registrados; nenhum upgrade involuntário; limites monitorados; escopo gratuito restrito aos testes. Para dados reais, aprovar uma arquitetura que atenda aos requisitos e ao orçamento.

CONFIGURAÇÃO E INTEGRAÇÃO

Infraestrutura e publicação da aplicação

Preparar os ambientes

- Criar desenvolvimento, homologação e produção separados por credenciais, banco, Redis e storage. A primeira homologação usa uma base vazia e dados fictícios.
- Provisionar PostgreSQL e Redis gerenciados com TLS, criptografia aplicável, regras de rede e contas mínimas. Restringir acesso administrativo e documentar o caminho de acesso emergencial.
- Definir WAF e balanceamento/proxy de entrada, proteção de endpoints operacionais e rate limits. Testar as regras sem bloquear indevidamente login, uploads e callbacks.
- Configurar secret manager, identidade do serviço e processo de rotação. O segredo deve ser injetado em execução, sem aparecer no Git, frontend, imagem ou logs.

Publicar com configuração reproduzível

O backend usa Java 25 e possui Dockerfile. A interface usa React, TypeScript e Vite, com pnpm no processo existente. Fixar a versão candidata, construir os artefatos e registrar identificadores das imagens. Separar publicação de aplicação e aplicação de migrations. [R4, R6]

No Supabase, o navegador deve continuar falando com a API Java. Desabilitar a Data API não utilizada ou retirar os schemas clínicos da exposição; revisar grants padrão antes de criar tabelas. Usar conexão PostgreSQL adequada ao servidor e validar o modo de pooler com o contexto transacional de tenant. [S5, S6]

Autenticação e topologia

A renovação de sessão usa cookie **SameSite=Strict**. Planejar site e API em uma topologia compatível, preferencialmente na mesma origem, e testar CSRF, login, renovação e logout. Liberar CORS não resolve sozinho cookies entre sites. Não afrouxar a segurança para contornar um desenho de hospedagem inadequado. [R7]

Domínio e capacidade

No teste pode ser usado endereço fornecido pela hospedagem. Para operação, definir titular do domínio, DNS, certificado HTTPS e renovação. Medir memória, tempo de inicialização, carga simultânea, conexões, latência e comportamento após reinício. Não há capacidade ou número de usuários homologados ainda.

Critério de conclusão

Ambiente reproduzível, HTTPS e conexões verificadas, endpoints internos protegidos, login completo funcional e teste de capacidade aprovado. A prontidão deve falhar quando uma dependência obrigatória fica indisponível.

DESENVOLVIMENTO E RECUPERAÇÃO

Storage privado e chaves de criptografia

A cópia local já contém **EncryptedClinicalExportStorage**, que cifra exportações antes de encaminhá-las a **PrivateObjectStorage**. Não foi localizada uma implementação concreta dessa interface para um fornecedor nos arquivos examinados. O perfil de produção mantém o storage desabilitado por padrão. [R4, R5]

Concluir a integração

- Escolher o serviço e implementar gravação, leitura, exclusão e verificação de saúde com credenciais protegidas. Uma interface Java ou bucket criado não comprova conexão real.
- Verificar privacidade do bucket, criptografia em repouso, durabilidade e política de retenção no provedor. O teste de saúde precisa comprovar as condições, sem simplesmente devolver sucesso.
- Separar retenção de exportações, documentos fiscais e backups. Para objetos imutáveis, adaptar a sonda de teste para não exigir exclusão incompatível com o bloqueio de retenção.
- Testar acesso anônimo negado, acesso de outra organização negado, conteúdo adulterado, chave incorreta, falha do provedor, objeto ausente e recuperação após reinício.
- Validar limites de tamanho e uso de memória. A camada atual trabalha com bytes em memória; exportações grandes precisam de limite coerente com a hospedagem.

Garantir recuperação das chaves

Inventariar JWT e as chaves MFA_ENCRYPTION_KEY, CLINICAL_KEY e AUDIT_HMAC_KEY. Usar material independente e aleatório conforme o runbook; preservar identificadores e versões antigas necessárias à leitura. Uma nova chave não decifra dados históricos.

Guardar cópia recuperável das chaves em local separado e controlado. Testar restauração do material criptográfico e rotação em homologação. Criptografia implementada na aplicação não equivale, por si só, a integração com KMS do provedor. [R1, R5]

Documentos fiscais

Verificar também a implementação de **FiscalDocumentStorage** e o ciclo de vida de XML/PDF. Não assumir que o adapter de exportação clínica cobre automaticamente a guarda fiscal.

Critério de conclusão

Objeto cifrado gravado e recuperado do fornecedor real; isolamento comprovado; chaves recuperáveis; retenção testada; disponibilidade refletida corretamente na prontidão. Não usar disco temporário do container como storage de produção.

BLOQUEADOR DE PRODUÇÃO

Base existente e validação do upgrade

Não executar migrations diretamente na base da clínica. A base existente ainda não foi identificada como teste ou produção. A nova API pode iniciar o Flyway automaticamente ao conectar; não usar a inicialização da aplicação como método de inspeção.

Antes de qualquer mudança

- Identificar servidor, ambiente, aplicação que utiliza a base, responsável, versão do PostgreSQL, tamanho e uso atual. Fazer inventário com acesso mínimo, sem divulgar dados de pacientes.
- Confirmar backup, autorização para cópia e acesso às chaves históricas. Criar clone em conta/servidor isolado, com credenciais diferentes e saída bloqueada para serviços reais.
- Exportar o histórico Flyway, comparar versões, checksums e scripts aplicados. Registrar o artefato atual da aplicação e a versão candidata.

Ponto	Validação obrigatória
Histórico	Revisar V11/V18/V25/V38/V76, pré-requisitos V07.1/V13.1/V75.1 e marcadores V19/V21/V32/V42. Divergência exige plano específico.
V20 e V26	Se houver prontuários/pagamentos legados, preparar conversão dedicada com vínculos, criptografia, auditoria e reconciliação preservados.
V85	Comparar moedas, valores financeiros e precisão antes/depois.
V86	Comprovar que timestamps antigos representam UTC antes da conversão para TIMESTAMPTZ.

A timezone atual do servidor não prova como datas antigas foram gravadas. Comparar eventos com horário conhecido, configuração histórica e regras de horário de verão. Não aplicar um deslocamento fixo de horas sem essa análise. [R1, R3]

Ensaiar e aprovar

Restaurar primeiro, validar a versão anterior e então ensaiar o upgrade no clone. Reconciliar contagens, relacionamentos, valores, instantes e conteúdo cifrado. Rodar validação Flyway e fluxos clínicos/financeiros. Não usar repair, baseline ou out-of-order para esconder incompatibilidades.

Critério de conclusão

Relatório sem divergências não explicadas, janela medida, plano de retorno e aprovação técnica/clínica. Voltar a imagem da aplicação não desfaz schema; restauração após novas gravações exige plano de reconciliação.

CONTINUIDADE DO SERVIÇO

Backups e ensaio de recuperação

RPO é o intervalo máximo de dados que a clínica aceita perder. **RTO** é o tempo máximo para restabelecer o serviço. Ambos precisam de metas aprovadas; não há metas nem tempos medidos registrados para a infraestrutura futura.

Configurar a proteção

- Automatizar backup do banco, habilitar PITR/WAL no plano escolhido e estabelecer cópia protegida contra alteração/exclusão indevida.
- Incluir arquivos, configurações e chaves no plano de recuperação. Dump do PostgreSQL não contém automaticamente os objetos do storage.
- Definir retenção, responsáveis, acesso, alertas de falha e período máximo sem cópia válida. Proteger e monitorar também o destino de backup.

Executar o exercício isolado

- Conferir conta, host e nome do banco de destino. O script confere o nome esperado e o SHA-256, mas isso não comprova que o servidor escolhido seja seguro.
- Restaurar com versão compatível do PostgreSQL, sem conectar a nova API ao banco original. O restore substitui dados no destino.
- Recriar e revisar owners, roles e grants: o script usa --no-owner e --no-privileges. Testar RLS com a role real de runtime.
- Recuperar chaves e objetos. Validar login/MFA, agenda, prontuário, financeiro e isolamento entre duas organizações.
- Para PITR, recuperar um horário-alvo e confirmar um marcador anterior presente e um posterior ausente. Restaurar apenas um dump não comprova PITR.
- Medir perda observada e tempo total desde o incidente simulado até a aplicação validada; incluir provisionamento, restore e testes.

Guardar evidências e repetir

Registrar origem/destino, versão, backup, checksum, horários, RPO/RTO observado, testes, falhas e aprovadores. Guardar evidências sem dados clínicos expostos. Repetir periodicamente e após alterações relevantes; definir a frequência com a clínica. [R1, R2]

Critério de conclusão

Recuperação demonstrada dentro das metas aprovadas, incluindo leitura cifrada e arquivos. Falha de recuperação impede uso com dados reais. Testes gratuitos com dados fictícios servem para aprender o procedimento, não para prometer continuidade clínica.

SEGURANÇA DA APLICAÇÃO

Isolamento de dados e controles do piloto

Já existem migrations para RLS e controles de tenant, além de validações da role de produção. Confirmar sua aplicação efetiva na base e o comportamento de todos os fluxos. Documentos antigos citam etapas ainda em preparação; o aceite deve considerar a versão candidata consolidada e os testes atuais. [R3, R4, R7]

Verificações obrigatórias

- Criar duas organizações fictícias e testar leitura, criação, alteração, exclusão, busca, exportação e acesso a arquivos. Trocar IDs e cabeçalhos não pode ampliar acesso.
- Testar contexto de tenant em transações, jobs, conexões reutilizadas, callbacks e dados legados. Revisar registros sem organização e acessos de suporte.
- Usar runtime sem SUPERUSER/BYPASSRLS nem caminhos indiretos de elevação. Revisar owners, privilégios, políticas e separação das credenciais de migrations.
- Validar MFA, recovery codes, revogação, expiração/renovação de sessão, CSRF, rate limits, CORS e permissões por função e vínculo clínico.
- Comprovar auditoria de leitura/escrita sensível e proteção da integridade, sem registrar conteúdo clínico ou segredos nos logs.

Chaves de configuração existentes

Controle	Função e validação pendente
CLINICAL_ONLY_PILOT	Restringe módulos no backend; padrão de produção atual é true. Validar todas as rotas, aliases e chamadas diretas.
CLINICAL_DATA_ENABLED	Padrão de produção atual é false. Habilitar acesso clínico somente após os requisitos de proteção e aceite.
VITE_CLINICAL_ONLY_PILOT e VITE_CLINICAL_DATA_ENABLED	Controlam a interface. Precisam estar alinhados ao backend; ocultar menu não constitui autorização.
REQUIRE_* e SCHEDULING_ENABLED	Os primeiros cobram integrações no readiness. Scheduling controla tarefas agendadas; nenhum deles substitui o bloqueio completo de operações.

Critério de conclusão

Matriz de rotas e papéis aprovada, testes negativos executados no navegador e diretamente na API, ausência de vazamento entre organizações e controles do piloto coerentes. Um HTTP 200 em /health/ready não substitui esses testes.

MÓDULOS CONDICIONAIS AO ESCOPO

Pagamentos assinaturas e comunicação

Pagamentos da clínica e assinatura do sistema

São fluxos diferentes: pagamento de atendimento pertence ao financeiro da clínica; cobrança de R\$299 pelo uso do software pertence ao billing SaaS. Há interfaces e registries, mas não foram encontrados adapters concretos de fornecedores nos diretórios examinados. Confirmar a cobertura da versão final. [R8]

- Escolher fornecedor, abrir conta empresarial, concluir cadastro e definir taxas, repasse, estorno, disputa e responsável pela conciliação.
- Implementar sandbox e produção separados, idempotência, assinatura de webhook, replay protection, consulta após timeout, repetição e reconciliação.
- Homologar aprovação, recusa, duplicidade, refund, cancelamento, recorrência e indisponibilidade. Testar que reproprocessamento não duplica cobrança nem altera saldo incorretamente.
- Definir onboarding da clínica, plano, limites, trial, inadimplência e saída/exportação. Se a assinatura for cobrada manualmente no início, formalizar o processo e manter automação fora do escopo.

E-mail e WhatsApp

- Selecionar fornecedores e validar remetente/domínio ou conta/número empresarial. Configurar SPF, DKIM e DMARC para e-mail conforme a documentação do serviço.
- Homologar modelos, elegibilidade do destinatário, consentimentos quando aplicáveis, opt-out, horários, retries, limites e callbacks de entrega/falha.
- Testar convites, confirmação de e-mail e recuperação de senha: confirmar a cobertura desses fluxos no backend e na interface antes de prometer acesso autônomo.
- Minimizar conteúdo de mensagens e dados pessoais nos logs; usar destinatários de teste em homologação.

O readiness atual agrupa e-mail e WhatsApp em REQUIRE_NOTIFICATION_PROVIDERS. Para liberar só um canal, será necessário tratar o escopo explicitamente, sem indicar que o outro está homologado. A rotina agendada só deve ser ativada depois de validar os fornecedores e as filas.

Critério de conclusão

Cada canal tem contrato/custo conhecido, integração testada e aceite separado. Módulos adiados permanecem bloqueados no servidor e fora da oferta inicial, com procedimento manual legítimo documentado quando necessário.

DEPENDÊNCIA CONTÁBIL E EXTERNA

Emissão fiscal em Sorocaba

O cliente nacional atual falha de forma explícita quando a integração não está homologada. O adapter municipal é uma base abstrata, não uma implementação pronta para Sorocaba. Escolher um emissor não conclui a integração. [R8]

Confirmar o canal aplicável

O contador deve confirmar CNPJ, inscrição municipal, regime tributário, serviço prestado, código aplicável e data de início. A Prefeitura mantém orientação de atendimento de NFS-e e acesso ao SIAC, mas isso não resolve sozinho o enquadramento de cada contribuinte. [S7]

A Receita Federal informa que ME/EPP optantes pelo Simples Nacional devem utilizar o Emissor Nacional a partir de **1º de novembro de 2026**. Confirmar com o contador como essa transição afeta a clínica e o fornecedor escolhido. Não presumir que basta uma integração municipal antiga. [S8]

Contratar e homologar

- Obter confirmação escrita do emissor sobre suporte ao canal, regime e município necessários, incluindo a transição de 2026 e layouts aceitos.
- Confirmar o tipo de certificado exigido, procurações, cadastro e credenciamento antes de comprar. Guardar certificado e senha com acesso restrito e alerta de renovação.
- Configurar ambiente de homologação ou procedimento oficial de testes, parâmetros fiscais, numeração, validação de XML e assinatura quando exigida.
- Testar emissão autorizada, rejeitada, timeout com consulta posterior, repetição sem duplicidade, cancelamento e substituição quando cabíveis.
- Verificar guarda e recuperação de XML/PDF, integridade e vínculo com o financeiro. Registrar protocolos e evidências sem expor dados pessoais.
- Definir atendimento a falhas, exportação dos documentos ao trocar de fornecedor e responsável por divergências tributárias.

Se a emissão automática ficar para depois

O piloto pode excluir a emissão dentro do sistema apenas se a clínica mantiver um processo fiscal adequado, orientado pelo contador. Deixar o módulo desabilitado não elimina as obrigações fiscais da clínica nem as dos fornecedores do software.

Critério de conclusão

Canal confirmado pelo contador, certificado compatível, testes aceitos e cliente real conectado ao sistema. Habilitação de produção registrada por responsável, com consulta e recuperação dos documentos funcionando.

APROVAÇÃO INSTITUCIONAL

Privacidade contratos e revisão independente

A clínica e os responsáveis pelo software precisam definir suas responsabilidades. Funcionalidades de LGPD e criptografia no código não substituem decisões sobre tratamento de dados, documentos aprovados e capacidade de responder a incidentes.

Documentos e decisões pendentes

- Mapear dados e finalidades: cadastro, agenda, prontuário, faturamento, mensagens, auditoria, suporte, backups e fornecedores.
- Definir controlador, operadores, suboperadores, responsável de privacidade e bases legais por finalidade. Não usar um consentimento genérico como solução universal.
- Aprovar aviso de privacidade, termos de uso, contrato de serviço e DPA/acordo de tratamento, com regras de acesso, confidencialidade, suporte e encerramento.
- Definir retenção por categoria, inclusive prontuários, documentos fiscais, logs, exportações e cópias de segurança; validar exigências profissionais e legais aplicáveis.
- Documentar pedidos de acesso, correção, exportação, bloqueio e exclusão quando cabível, além de identidade do solicitante e prazo operacional.
- Revisar localização dos dados, subprocessadores e transferências internacionais. Região brasileira não comprova, sozinha, conformidade integral.

Plano de incidentes

Definir quem recebe o alerta, contém o incidente, preserva evidências, avalia impacto e decide a comunicação. A ANPD informa prazo geral de três dias úteis para comunicações cabíveis, sujeito às condições e exceções aplicáveis. A assessoria deve validar o enquadramento e o fluxo. [S9]

Avaliação independente de segurança

Contratar ou obter uma revisão realmente independente, com escopo e autorização definidos. Incluir isolamento entre clínicas, acesso a prontuários, autenticação, sessões, uploads/exports, callbacks, segredos, configurações de nuvem e recuperação. Usar ambiente controlado e registrar achados por gravidade.

Corrigir bloqueadores, executar reteste e registrar aceites. A revisão entre os dois desenvolvedores é útil, mas não equivale à avaliação independente prevista no checklist.

Critério de conclusão

Versões dos documentos aprovadas pela clínica e assessoria, responsabilidades assinadas, plano de incidentes exercitado e relatório independente com reteste das correções. Não prometer certificação de segurança ou conformidade sem comprovação.

VALIDAÇÃO ANTES DA LIBERAÇÃO

Testes pipeline e versão candidata

O repositório possui pipeline de frontend, backend, revisão de migrations e construção de containers. A presença do arquivo do pipeline não comprova a execução aprovada da versão que será implantada. Consolidar também os arquivos novos e alterações locais antes da validação final. [R6]

Executar na mesma versão que será publicada

- Frontend: instalação pelo lockfile, lint, verificação de tipos, testes e build. Confirmar ausência de segredos, URLs locais e demonstração indevida no pacote publicado.
- Backend: Java 25, execução de verify e testes de integração com PostgreSQL/Redis nas versões escolhidas. Registrar relatórios e ambiente utilizado.
- Migrations: banco vazio e cópia protegida de base existente; comparação de histórico e checksums; nenhuma reparação automática de divergências.
- Containers: build limpo, dependências e imagens verificadas, execução com permissões mínimas e configuração externa.
- Segurança: varredura de dependências/imagens, busca de segredos e revisão de acessos. O pipeline atual faz verificações específicas; ampliar o que faltar para a política de release.

Área	Casos de aceite
Acesso	Login, MFA, logout, revogação, recuperação de conta, CSRF e permissões.
Clínica	Cadastro, agenda, recorrência, reagendamento, prontuário, revisões/adendos e exportação.
Organizações	Troca de organização, vínculo profissional, suporte e negação de acesso cruzado.
Financeiro e canais	Valores, conciliação, idempotência e callbacks dos módulos habilitados.
Resiliência	Indisponibilidade de banco/Redis/storage, reinício, timeout, recuperação e alertas.

Completar o processo de publicação

Criar ambiente de homologação, aprovação da versão, artefato imutável, registro da configuração, controle da execução de migrations e teste pós-publicação. Guardar versão anterior e ensaiar retorno compatível. Definir critério de cancelamento da publicação.

Critério de conclusão

Relatórios aprovados vinculados ao commit e às imagens publicados, sem falhas críticas abertas. Fazer teste de carga com metas aprovadas e validação por usuário da clínica; não substituir isso por um percentual de cobertura isolado.

OPERAÇÃO DIÁRIA

Monitoramento suporte e início do piloto

Configurar observabilidade útil

- Disponibilidade externa, taxa de erro, latência, memória, conexões, armazenamento, Redis e cotas dos serviços.
- Idade do último backup válido, falha de restore, expiração de certificados, filas/retries e falhas dos fornecedores habilitados.
- Eventos de segurança e volume incomum de exportações ou mensagens; correlação de incidentes sem conteúdo clínico exposto.
- Retenção e acesso aos logs definidos. Restringir endpoints de métricas/administração e testar o recebimento e a confirmação de alertas.

Definir suporte entre os dois responsáveis

Atribuir titular e substituto, horário atendido, canal de contato, tempo de resposta acordado e escalonamento à clínica. Registrar procedimento de troca de senha/chave, restauração, indisponibilidade do fornecedor e saída de um responsável. Não vender plantão 24 horas sem capacidade real de atendimento.

Executar um piloto controlado

- Aprovar funções incluídas, número de participantes, duração, treinamento, canal de feedback e plano de contingência.
- Começar com dados fictícios. Entrada de dados reais exige todos os P0 resolvidos e habilitação explícita dos controles clínicos.
- Orientar a equipe da clínica sobre acessos individuais, MFA, permissões e tratamento de falhas. Confirmar quem pode consultar e alterar cada informação.
- Revisar erros, desempenho, recuperação e incidentes ao longo do piloto. Expandir usuários ou módulos somente após avaliar os resultados.

Condições para interromper

Vazamento entre organizações, perda/corrupção de dados, falha de recuperação, acesso indevido ou incidente grave exigem contenção e interrupção do fluxo afetado. Preservar evidências e acionar os responsáveis; não apagar registros para esconder o problema.

Critério de conclusão

Alertas recebidos e testados, suporte com dono e substituto, contingência ensaiada e aceite da clínica. O piloto termina com decisão registrada sobre continuidade, correções ou suspensão, sem expansão automática.

PLANO PARA OS DOIS TÉCNICOS

Divisão de trabalho e ordem de execução

Atribuir os nomes a A e B antes de começar. As etapas abaixo são uma proposta de organização; datas e esforço dependem da identificação da base, do escopo e dos fornecedores.

Etapa	Técnico A	Técnico B	Saída necessária
1 Preparação	Contas, MFA, inventário de serviços e desenho do ambiente.	Identificar base, chaves, histórico e escopo dos módulos.	Ambiente original identificado e plano de testes fictícios.
2 Homologação	Hospedagem, TLS, segredos, acesso e topologia de sessão.	Banco vazio, Redis, adapter de storage e testes de integração.	Fluxos em homologação e restrições do piloto comprovados.
3 Proteção	Isolamento, autenticação, monitoramento e revisão do restore.	Backup/PITR, restore drill, clone e ensaio de upgrade.	RPO/RTO e histórico/V86 aprovados.
4 Serviços	Fluxos de interface, permissões e verificação de callbacks.	Pagamento, billing, comunicação e fiscal conforme escopo.	Homologação por canal ou bloqueio formal de módulos adiados.
5 Liberação	Pipeline, publicação, alertas e suporte.	Revisão das evidências, reconciliação e contingência.	Revisão independente, aceites e piloto autorizado.

Atividades externas em paralelo

A clínica define responsáveis, finalidade dos dados, metas de recuperação e escopo. O contador valida a emissão e parâmetros fiscais. A assessoria revisa privacidade e contratos. O avaliador independente revisa a segurança. Nenhuma dessas aprovações deve ser presumida pelos desenvolvedores.

Dependências que determinam a sequência

- Fornecedor escolhido e conta pronta antes de implementar e homologar seu adapter.
- Base identificada e backup recuperável antes de ensaiar o upgrade; clone validado antes de mudar a origem.
- Versão consolidada antes de executar os testes finais e reunir evidências.
- Todos os bloqueadores de dados reais resolvidos antes de liberar o piloto clínico.

CHECKLIST FINAL

Registro de evidências e aceite de produção

Para cada item, registrar executor, data, versão, resultado, evidência e aprovador. O estado inicial é pendente. Não marcar aprovado apenas porque o código existe ou o serviço foi contratado.

Verificação	Evidência mínima
Base e upgrade	Inventário, autorização, histórico Flyway, reconciliação do clone e validação de fuso da V86.
Infraestrutura e segredos	Configuração revisada, roles mínimas, TLS, rede e teste de recuperação das chaves.
Storage e backup	Acesso negado sem permissão, recuperação de objetos, relatório de restore e PITR com RPO/RTO.
Segurança e qualidade	Testes da versão candidata, matriz de acesso, revisão independente e reteste.
Módulos externos	Homologação dos canais habilitados; exclusões documentadas e bloqueadas no servidor.
Operação e documentos	Alertas recebidos, suporte, contingência, contratos/privacidade e aceite clínico.

Campos do exercício de recuperação

Meta de RPO: _____ Meta de RTO: _____
Instante do incidente simulado: _____
Último dado recuperado: _____
Serviço validado às: _____
RPO observado: _____ RTO observado: _____
Backup e evidência em local restrito: _____
Executor e revisor: _____

Decisão sobre a liberação

Escopo autorizado: _____
Módulos desabilitados: _____
Versão e ambiente: _____
Pendências bloqueadoras: _____
Responsável técnico e data: _____
Responsável da clínica e data: _____
Aceites jurídico/contábil aplicáveis: _____

Resultado inicial: não liberado. Alterar para liberado somente após reunir as evidências e aprovações. Guardar o registro em local privado, com controle de acesso e sem inserir senhas, chaves ou prontuários no repositório.

REFERÊNCIAS PARA A EXECUÇÃO

Fontes e glossário

Referência técnica do levantamento: checkout local do PsicoGest em 25/09/2026, com HEAD a846989 e alterações locais em andamento. Fixar um commit candidato e repetir os testes antes do aceite. A preparação deste documento não executou deploy, restore, migrations ou uma nova bateria completa de testes.

Referências do projeto

R1 docs/production-runbook.md e ops/backup-postgres.ps1, restore-postgres.ps1, postgres-common.ps1
Operação, histórico, chaves e recuperação.

R2 docs/implantacao-inicial.md e docs/implantacao-evidencias-modelo.md
Plano inicial e formulários de evidências.

R3 backend/psicogest/psicogest/docs/saas-v1.0-readiness.md e resources/bd/migration
Requisitos SaaS e migrations V75, V76, V85 e V86.

R4 application-production.properties e security/config/Production*Validator.java
Configuração e validações de produção.

R5 infrastructure/storage/ e security/crypto/
Storage privado, camada de exportação cifrada e chaves.

R6 .github/workflows/quality.yml, Dockerfiles e frontend/package.json
Builds e pipeline de qualidade.

R7 security/pilot/, security/auth/refresh/ e frontend/src/shared/lib/pilot-scope.ts
Escopo do piloto e sessão.

R8 infrastructure/payment/, notification/, saas/billing/ e service/fiscal/
Contratos de integração e cliente fiscal bloqueado.

Nos caminhos abreviados Java, a base é backend/psicogest/psicogest/src/main/java/com/psicogest/psicogest/. Resources fica em src/main/resources/.

Fontes externas oficiais

S1 [Render Free](#)

S2 [Supabase planos e limites](#)

S3 [Upstash planos Redis](#)

S4 [Upstash segurança](#)

S5 [Supabase segurança da Data API](#)

S6 [Supabase conexões PostgreSQL](#)

S7 [Prefeitura de Sorocaba orientação NFS-e](#)

S8 [Receita Federal Emissor Nacional em novembro de 2026](#)

S9 [ANPD comunicação de incidentes](#)

Links clicáveis. Planos, limites e regras devem ser reconfirmados antes da contratação e da entrada em produção.

Termos usados

Tenant organização isolada. **RLS** regras de acesso por linha no banco. **PITR** recuperação até um instante escolhido. **KMS** serviço de gestão de chaves. **DPA** acordo sobre tratamento de dados. **Webhook** callback de um fornecedor. **Idempotência** repetir uma operação sem duplicar seu efeito. **Readiness** verificação das dependências para receber tráfego.